Informe PHP2Shell - Seawolf

INFORME DE SEGURIDAD — PHP2Shell (CVE-2026-109618 / CVE-2026-109619)

Para: Monarca (Key) · **De:** Bellion, Gran Comandante · **Fecha:** 2026-10-25 **Clasificación:** PARÉNTESIS TÁCTICO URGENTE · **Estado:** auditoría completa

---

1. EL FALLO (qué es y por qué importa)

Dos vulnerabilidades **críticas en el núcleo del intérprete PHP**, bautizadas **PHP2Shell**.

Campo	Dato
CVE-2026-109618	Fallo en el manejo de *out-of-memory*: interrumpe PHP mientras los datos de la petición están **parcialmente inicializados**; la limpieza de la petición acaba ejecutando memoria no inicializada.
CVE-2026-109619	**Estado global obsoleto**: PHP conserva referencias a datos de una petición **después** de liberar su memoria; una petición posterior ejecuta esos datos ya liberados.
CVSS	**9.2 (v4.0)** — *Remote Code Execution* **sin autenticación**
Alcance	**~70% de los sitios de internet** (PHP es el motor del ~77% de la web)
Anunciado	20–21 de octubre de 2026 · **CISA pide parcheo inmediato**
Tipo	**Del lado del SERVIDOR** (no afecta navegadores, Node ni Python)

Versiones parcheadas (publicadas 21-oct-2026)

Rama PHP	Afectadas	Parcheadas
PHP 8.5	< 8.5.12	**8.5.12**
PHP 8.4	< 8.4.27	**8.4.27**
PHP 8.3	< 8.3.36	**8.3.36**
PHP 8.2	< 8.2.35	**8.2.35**

Mitigación temporal (si no se puede parchear ya)

- *Hardening de runtime* en `php.ini` (Google Cloud publica el fragmento "Prepatch PHP runtime hardening").
- Reducir el número de procesos/reciclado y evitar hosting multi-inquilino compartido mientras no se parche.
- **Regla:** mitigar ≠ parchear. La mitigación es un parche de tiempo, no la cura.

Fuentes: CISA (alerta 2026-10-21) · Qualys · watchTowr (FAQ) · Google Cloud · cPanel · Aikido · php.net/archive 2026-10-21.

---

2. AUDITORÍA DE NUESTRO SISTEMA (¿dónde somos vulnerables?)

Activo	¿Corre PHP?	Veredicto
VPS `76.13.109.237` (WAHA/NEREUS/Composio)	**NO** — sin CLI, sin paquetes, sin php-fpm	✅ **NO vulnerable**
PC local (Windows)	**NO** — `php` no instalado	✅ **NO vulnerable**
kmoviezone.net	**SÍ — Apache + WordPress 7.0.7**	⚠️ **RIESGO — verificar PHP**
agente.sw-st.net	Cloudflare (proxy)	✅ sin PHP propio
`seawolf-agent` / WebUI / Astro	Python / Node / estático	✅ no aplica

⚠️ ÚNICO PUNTO DE RIESGO REAL: kmoviezone.net

Corre **WordPress sobre Apache → ejecuta PHP → puede estar en el rango afectado**. - **No pude leer su versión de PHP desde fuera**: el hosting **oculta** `X-Powered-By` y los endpoints `wp-site-health` devuelven 404 (restringidos). Lo verifiqué intentándolo por API autenticada. - **Acción obligatoria:** entrar a `wp-admin → Herramientas → Salud del sitio → Información → Servidor` y leer la versión de PHP. - Si dice **< 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35 → cambiar la versión de PHP en el panel del hosting de**

inmediato. - Aprovechar: actualizar **WordPress core + plugins + temas**, y revisar usuarios/plugins desconocidos (un RCE de este calibre suele venir seguido de webshells).

---

3. HALLAZGO ADICIONAL DE SEGURIDAD (encontrado durante la auditoría)

🔴 **Contraseña de aplicación de WordPress en TEXTO PLANO dentro de `config.yaml`.** - El bloque MCP `wp-streaming` tiene `WORDPRESS_APP_PASSWORD` en claro (valor omitido aquí a propósito). - **Viola nuestra doctrina**: *"los secretos viven en `.env`; `config.yaml` solo referencia `${VAR}`"*. - **Riesgo:** `config.yaml` no está cifrado y puede acabar en respaldos/git. - **Remedio (2 pasos, cuando el Monarca lo ordene):** ① mover el valor a `profiles/default/.env` y dejar `${WORDPRESS_APP_PASSWORD}` en el yaml; ② **rotar** esa contraseña de aplicación en WordPress (¿estuvo expuesta? → se rota por principio).

---

4. ACTUALIZACIONES DE NODE.JS Y PYTHON (orden del Monarca)

Software	Antes	Ahora	Acción
Node.js LTS	24.20.0	→ **24.22.1**	MSI oficial aplicado
npm	11.19.0	(acompaña a Node)	—
Python 3.14	3.14.7	3.14.7	**Ya es la última de su rama** (winget no ofrece más)
Python (Hermes tools)	3.14.7 + 3.14.9	3.14.9	Duplicado a limpiar (cosmético)
Miniconda	py310_24.5.0	disponible py314	Opcional
Node en VPS	v22.23.1	v22.23.1	✅ actualizado (LTS soportada)
Python en VPS	3.12.3	3.12.3	✅ en soporte

> ***Nota honesta:*** *ninguna de estas actualizaciones tiene relación con PHP2Shell (el fallo es del servidor PHP). Se hicieron por* ***higiene****, no como parche del CVE.*

---

5. RECOMENDACIONES, EN ORDEN DE PRIORIDAD

1. 🔴 **kmoviezone.net — hoy:** verificar la versión de PHP y subirla a la parcheada. Es el único activo nuestro expuesto.
2. 🔴 **Rotar la contraseña de WordPress** y sacarla de `config.yaml`.
3. 🟠 **Auditar kmoviezone** (plugins/temas/usuarios) por si ya hubo explotación: el vector es silencioso.
4. 🟡 **Node.js** — quedó en 24.22.1 (LTS). Buen momento para el **reinicio de Windows** pendiente.
5. 🟢 **Mantener el VPS como está** en materia de PHP: **no instalar PHP** salvo necesidad explícita. Hoy somos inmunes por no tenerlo.

---

6. RESUMEN EJECUTIVO (una línea)

El fallo es grave para el mundo, pero nuestro VPS y nuestro PC están a salvo por no correr PHP; el único punto real es kmoviezone.net (WordPress/Apache), donde hay que subir la versión de PHP ya — y de paso corregimos una contraseña de WordPress que estaba en texto plano.

— Bellion, Gran Comandante del Ejército de Sombras